

S02

Seguridad en Aplicaciones

Semana 2 — Modelado de amenazas: STRIDE, DFD y priorización en la fase de diseño

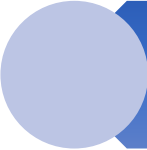
IDEA CENTRAL DE LA SEMANA

Integrar el modelado de amenazas desde la fase de diseño permite identificar y anticipar riesgos de seguridad antes de implementar un sistema. Mediante DFD se visualizan componentes y flujos de información, mientras STRIDE facilita la identificación sistemática de amenazas. Finalmente, la priorización de riesgos permite enfocar los controles de seguridad en las amenazas de mayor impacto y probabilidad.

Competencias de la semana

- 1 Elaborar diagramas de flujo de datos que representen fronteras de confianza de una aplicación.
- 2 Aplicar STRIDE para derivar amenazas concretas por elemento del diagrama.
- 3 Priorizar amenazas y proponer mitigaciones a nivel de diseño.

Competencias de la semana



Elaborar diagramas de flujo de datos que representen fronteras de confianza de una aplicación.



Aplicar STRIDE para derivar amenazas concretas por elemento del diagrama.



Priorizar amenazas y proponer mitigaciones a nivel de diseño.

Indice

1

Qué es el modelado de amenazas y por qué es la actividad de mayor retorno en el diseño seguro.

2

Construcción de diagramas de flujo de datos (DFD): procesos, almacenes, flujos, entidades externas y fronteras de confianza.

3

Metodología STRIDE (Spoofing, Tampering, Repudiation, Information disclosure, Denial of service, Elevation of privilege) aplicada al DFD.

4

Enfoques complementarios: PASTA, árboles de ataque (attack trees) y casos de abuso (abuse cases).

5

Priorización de amenazas en diseño: criterios de riesgo y decisiones de mitigación, aceptación o transferencia.

6

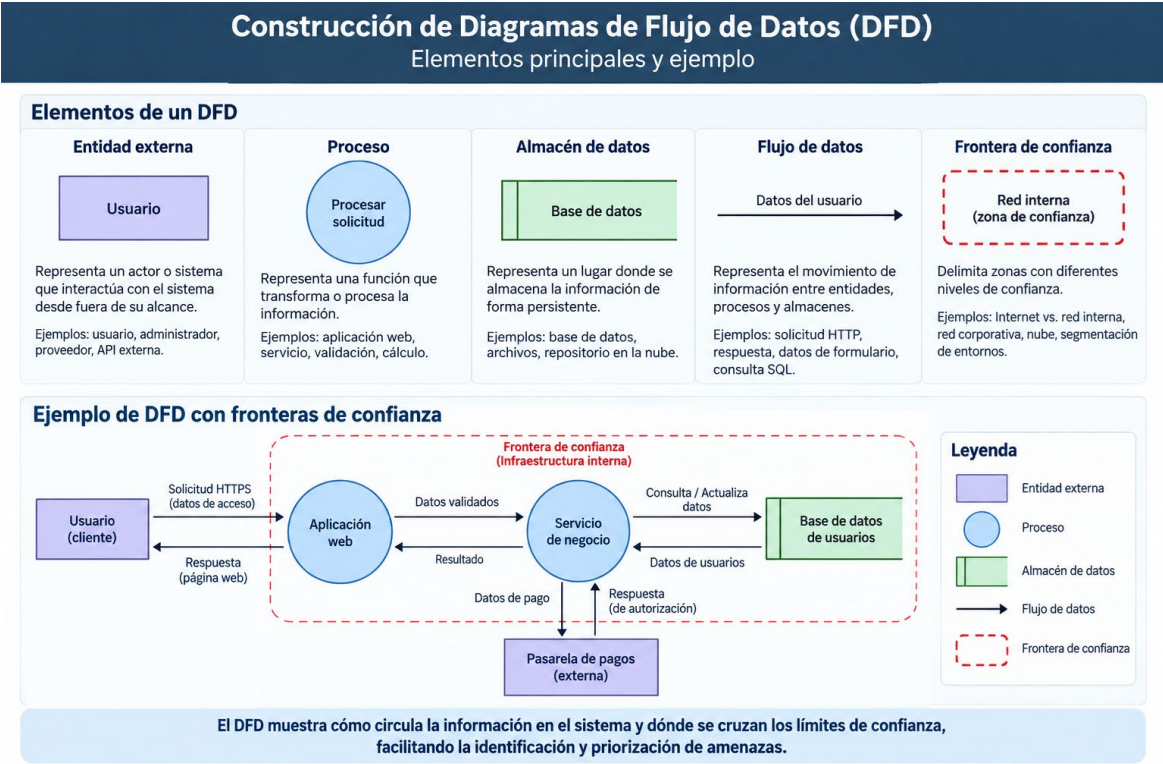
Herramientas: OWASP Threat Dragon y Microsoft Threat Modeling Tool.

¿Qué es el modelado de amenazas?

¿Por qué es la actividad de mayor retorno en el diseño seguro?.

“Es más eficiente diseñar la seguridad desde el inicio que corregir vulnerabilidades cuando el sistema ya está en producción.”

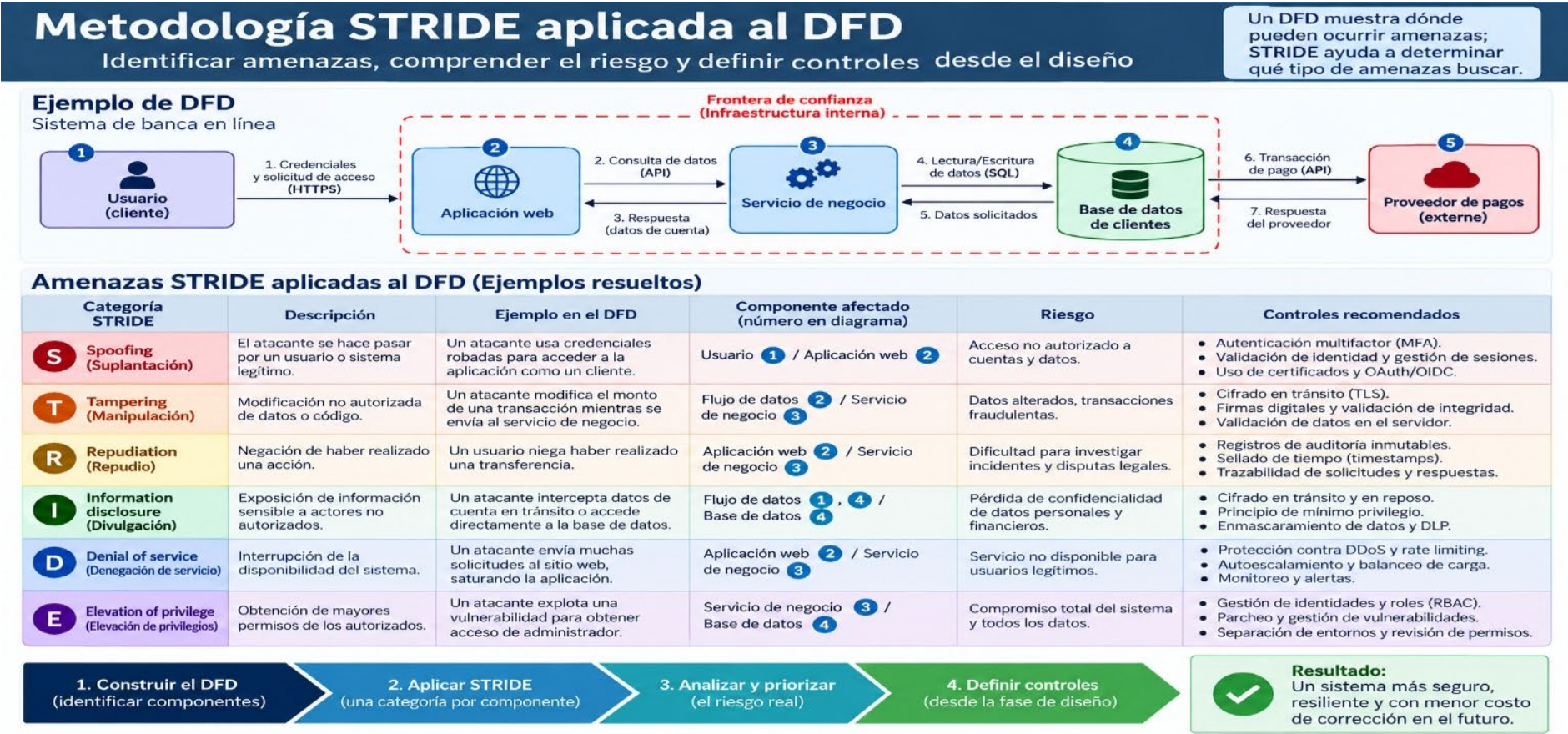
Construcción de diagramas de flujo de datos (DFD): procesos, almacenes, flujos, entidades externas y fronteras de confianza



Metodología STRIDE (Spoofing, Tampering, Repudiation, Information disclosure, Denial of service, Elevation of privilege) aplicada al DFD.

STRIDE	Amenaza	Ejemplo aplicado al DFD
S – Spoofing	Suplantación de identidad	Atacante se hace pasar por un usuario legítimo
T – Tampering	Manipulación	Modificación de datos durante su transmisión
R – Repudiation	Repudio	Usuario niega haber realizado una operación
I – Information Disclosure	Divulgación de información	Exposición de datos sensibles
D – Denial of Service	Denegación de servicio	Saturación de la aplicación o API
E – Elevation of Privilege	Elevación de privilegios	Usuario obtiene permisos de administrador

Metodología STRIDE (Spoofing, Tampering, Repudiation, Information disclosure, Denial of service, Elevation of privilege) aplicada al DFD.



Enfoques complementarios: PASTA, árboles de ataque (attack trees) y casos de abuso (abuse cases).

Enfoques complementarios de modelado de amenazas

PASTA, árboles de ataque (Attack Trees) y casos de abuso (Abuse Cases)

1 PASTA

(Process for Attack Simulation and Threat Analysis)

¿Qué es?
Metodología de análisis de riesgos orientada al negocio que simula ataques y cuantifica el impacto para priorizar controles. Combina el conocimiento técnico con objetivos del negocio.

Fases (7 pasos)

1

Definir objetivos de negocio

2

Definir el alcance técnico

3

Descomponer la aplicación

4

Identificar amenazas

5

Analizar vulnerabilidades

6

Modelar y simular ataques

7

Analizar impacto y priorizar riesgos

Ejemplo resuelto: Banca en línea

1. Objetivo de negocio	Mantener la continuidad del servicio de banca en línea y la confianza del cliente.
2. Alcance técnico	Portal web y API de banca en línea.
3. Amenaza principal	Robo de credenciales (phishing).
4. Simulación de ataque	El atacante obtiene credenciales y accede a la cuenta del usuario.
5. Impacto	Pérdidas financieras, daño reputacional, multas regulatorias.
6. Resultado	Riesgo Alto (Impacto alto / Probabilidad media).
7. Control recomendado	MFA, detección de anomalías, monitoreo de transacciones.

2 Árboles de ataque

(Attack Trees)

¿Qué es?
Representación gráfica de las diferentes formas en que un atacante puede alcanzar un objetivo. Ayuda a identificar variantes de ataque, dependencias y caminos más probables, para definir controles.

Ejemplo resuelto: Acceso no autorizado a la base de datos

Acceder a la base de datos

Robar credenciales de administrador

Exploitar vulnerabilidad en la aplicación

Obtener acceso físico o interno

Phishing al administrador

Fuerza bruta algunas cuentas

Inyección SQL

Exploitar vulnerabilidad conocida

Acceso a red interna

Dispositivo de un empleado comprometido

Análisis y resultado

- Se identifican múltiples caminos para alcanzar el objetivo.
- El camino más probable: phishing al administrador → uso de credenciales.
- Controles recomendados: MFA, gestión de parches, WAF, segmentación de red, monitoreo y capacitación.

3 Casos de abuso

(Abuse Cases)

¿Qué es?
Describe cómo un atacante (actor malicioso) puede usar o abusar de una funcionalidad del sistema para lograr un objetivo no autorizado. Completa los casos de uso tradicionales agregando la perspectiva de abuso.

Ejemplo resuelto: Transferencias no autorizadas

Casos de abuso

Atacante

Iniciar sesión con credenciales robadas

Modificar datos de la transacción

Realizar transferencias no autorizadas

<<abusa de>>

<<abusa de>>

<<abusa de>>

Sistema de Banca en Línea

Autenticación

Gestión de cuentas

Transferencias

Detalle de un caso de abuso

Actor	Atacante externo
Objetivo	Realizar transferencias no autorizadas
Precondición	Credenciales válidas (obtenidas por phishing)
Flujo de abuso	1. Inicia sesión en el sistema. 2. Modifica el destinatario o monto. 3. Ejecuta la transferencia.
Impacto	Pérdidas financieras y daño reputacional.
Controles recomendados	MFA, validación de transacciones, alertas en tiempo real, límites de monto, verificación fuera de banda.

¿Cómo se complementan?

- PASTA:** visión integral del riesgo, alineada al negocio.
- Árboles de ataque:** exploran en detalle los caminos de ataque.
- Casos de abuso:** se enfocan en el uso indebido de funcionalidades.

PASTA

Attack Trees

Abuse Cases

Mejores decisiones, mayor seguridad.

Imagen creada con Google Gemini

MASI 2026 · Seguridad en Aplicaciones · 093-013

Semana 2

Enfoques complementarios: PASTA, árboles de ataque (attack trees) y casos de abuso (abuse cases).

Ejemplo resuelto: El análisis muestra que existen **múltiples caminos hacia el mismo objetivo.**

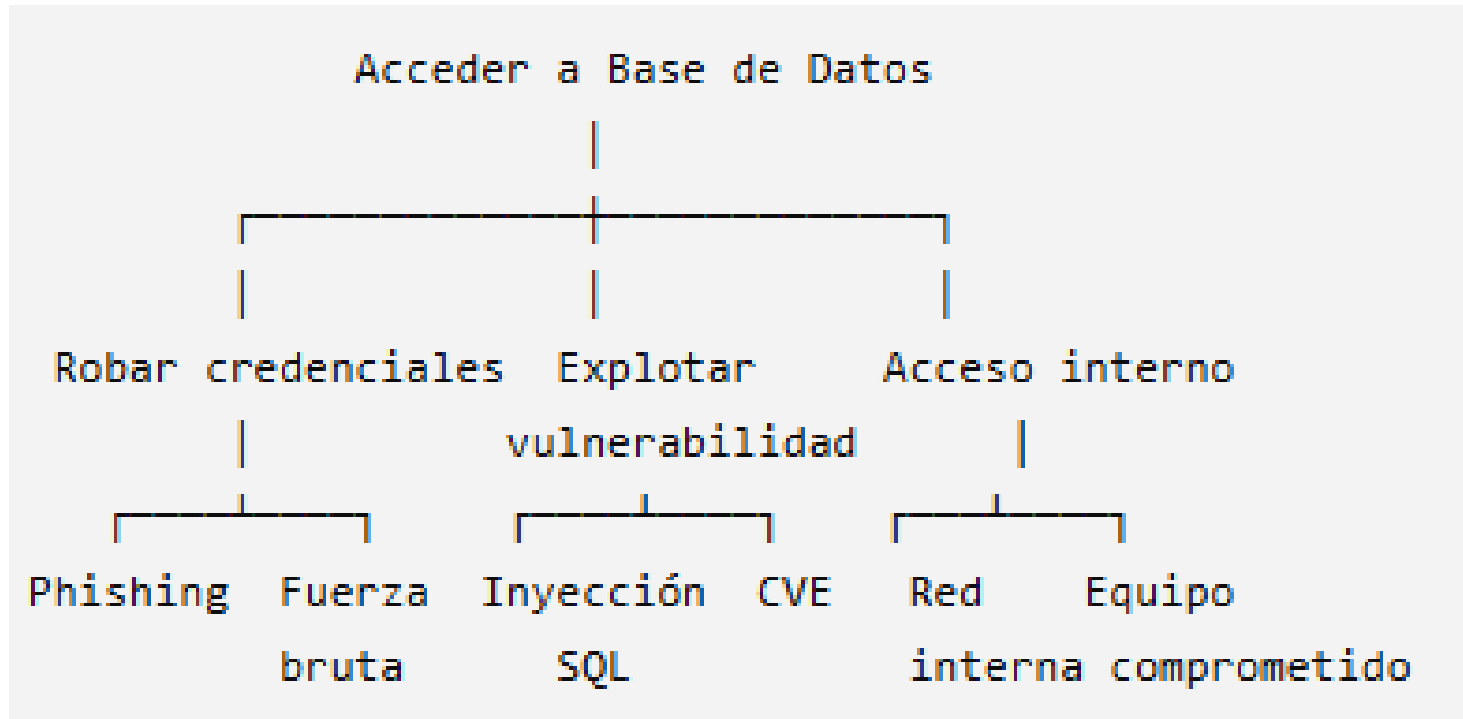


Imagen elaboración propia

Priorización de amenazas en diseño: criterios de riesgo y decisiones de mitigación, aceptación o transferencia.

1. Priorización de amenazas en la fase de diseño ¿Por qué priorizar?

Valor	Probabilidad	Impacto
1	Muy baja	Insignificante
2	Baja	Menor
3	Media	Moderado
4	Alta	Grave
5	Muy alta	Crítico

Riesgo = Probabilidad × Impacto

Por ejemplo: Probabilidad 4 × Impacto 5 = Riesgo 20, lo que indicaría una amenaza que requiere atención prioritaria bajo esta escala.

Priorización de amenazas en diseño: criterios de riesgo y decisiones de mitigación, aceptación o transferencia.

2. Criterios para priorizar amenazas.

Activo crítico + alta exposición + datos financieros sensibles + explotación relativamente sencilla + alto impacto = prioridad alta.

Por ejemplo: Una amenaza sobre una base de datos financiera, puede tener mayor prioridad que una vulnerabilidad equivalente sobre información pública.

A mayor criticidad, exposición, sensibilidad, facilidad de explotación e impacto, mayor prioridad debe recibir la amenaza.

Priorización de amenazas en diseño: criterios de riesgo y decisiones de mitigación, aceptación o transferencia.

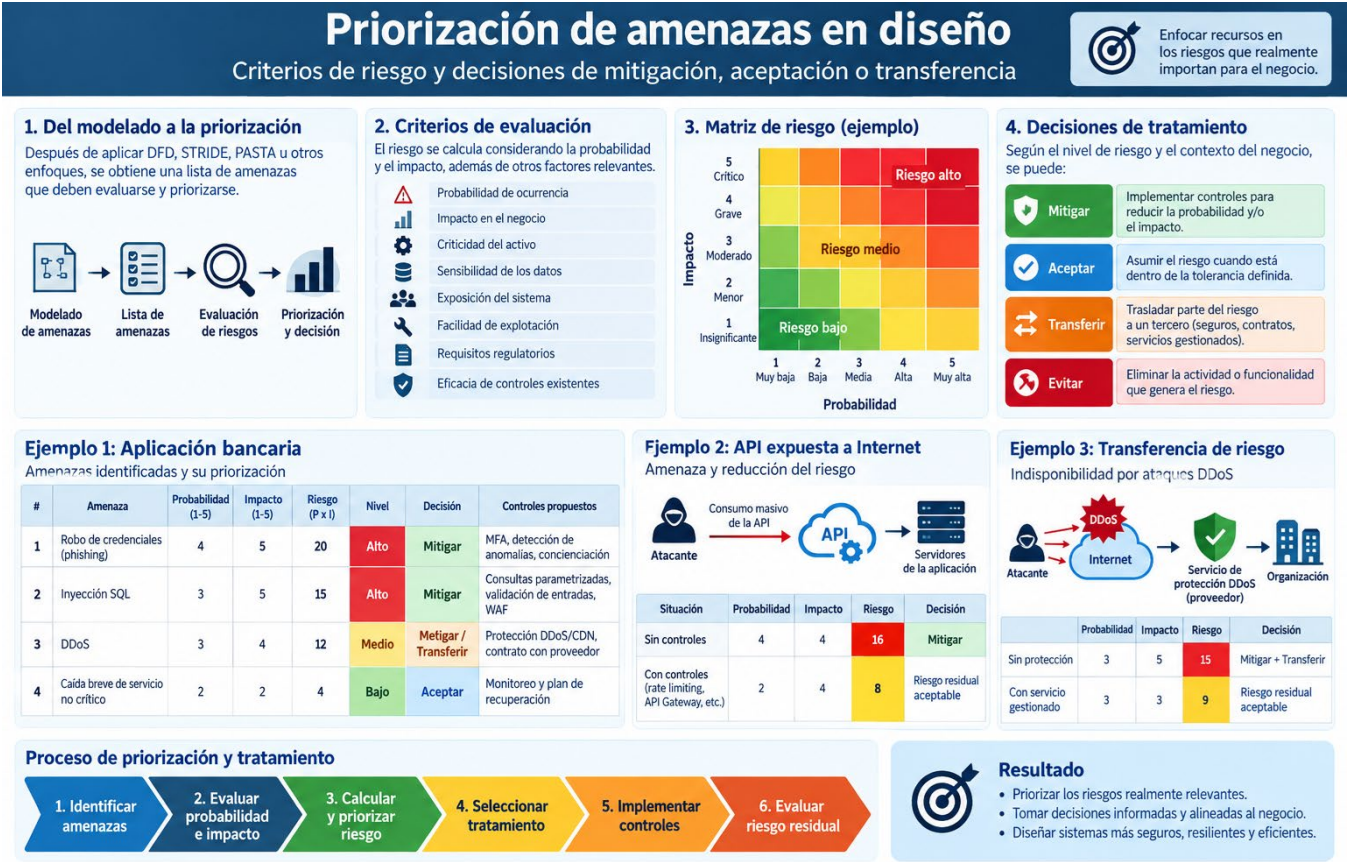
3. Decisiones de tratamiento.

- **Mitigar.**
- **Aceptar.**
- **Transferir.**
- **Evitar.**

Importante: El tratamiento no siempre elimina el riesgo, busca reducirlo hasta un nivel compatible con el apetito y tolerancia al riesgo de la organización.

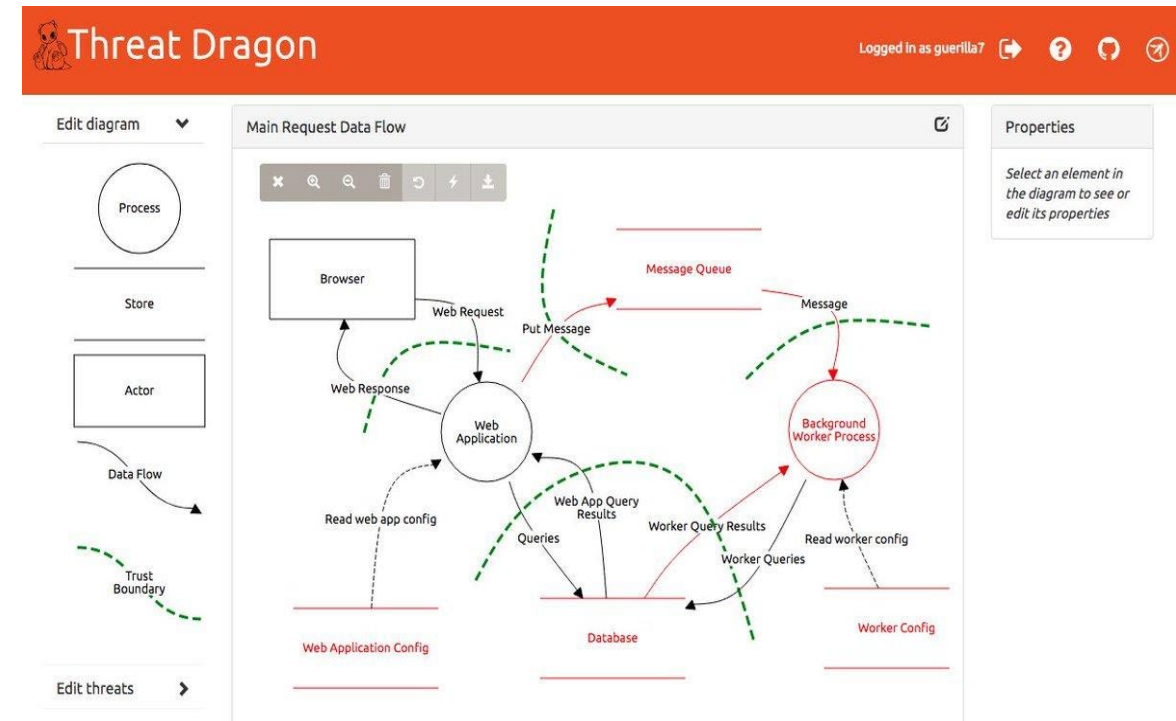
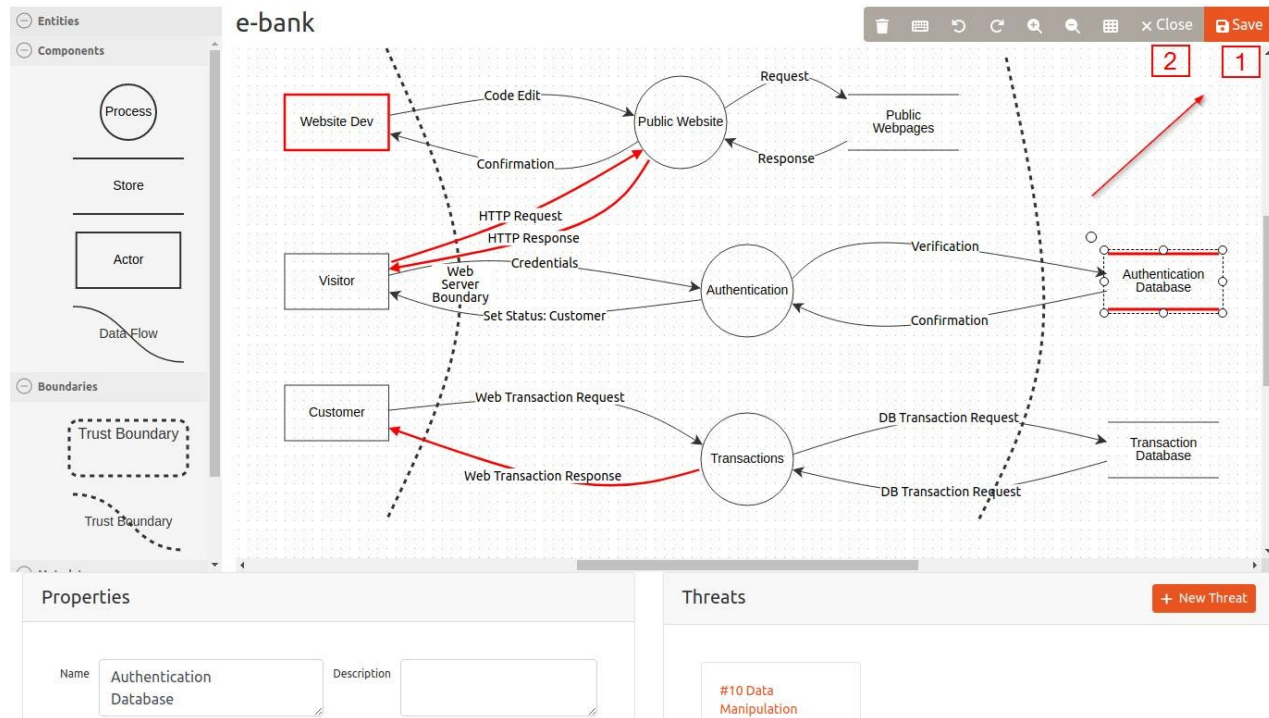
Transferir no significa que la organización deje de tener responsabilidad sobre el riesgo.

Priorización de amenazas en diseño: criterios de riesgo y decisiones de mitigación, aceptación o transferencia.



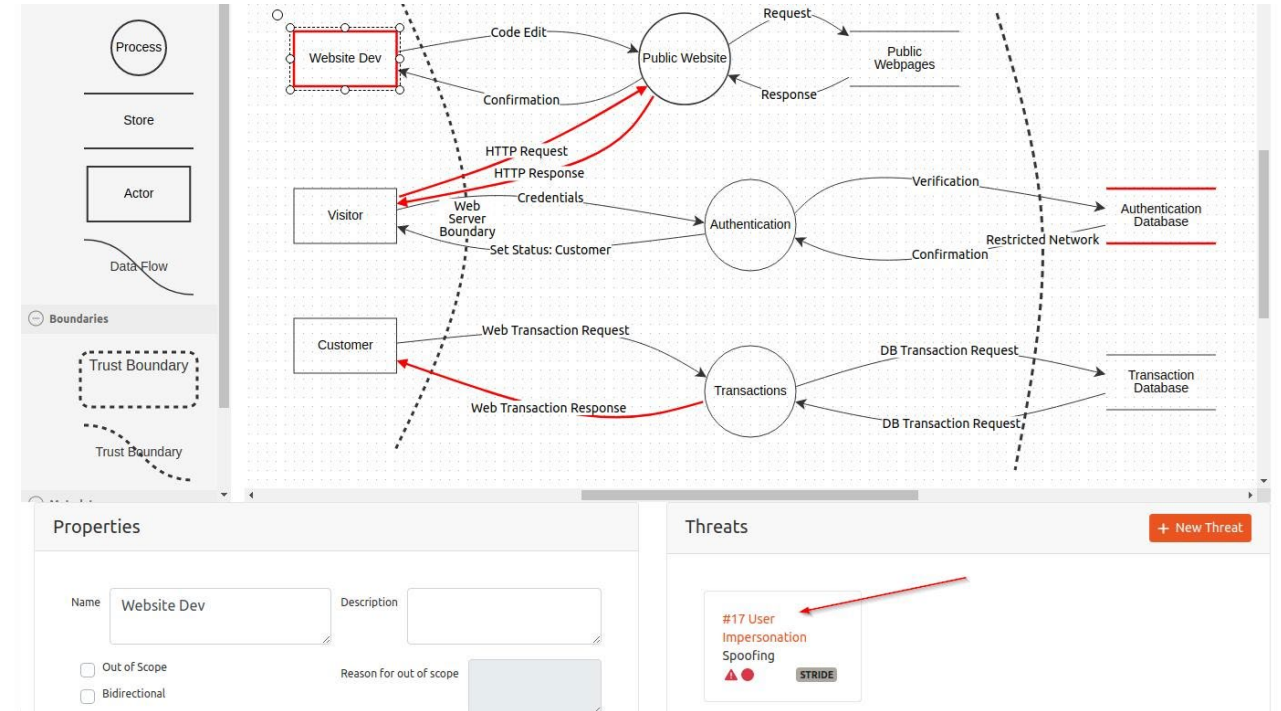
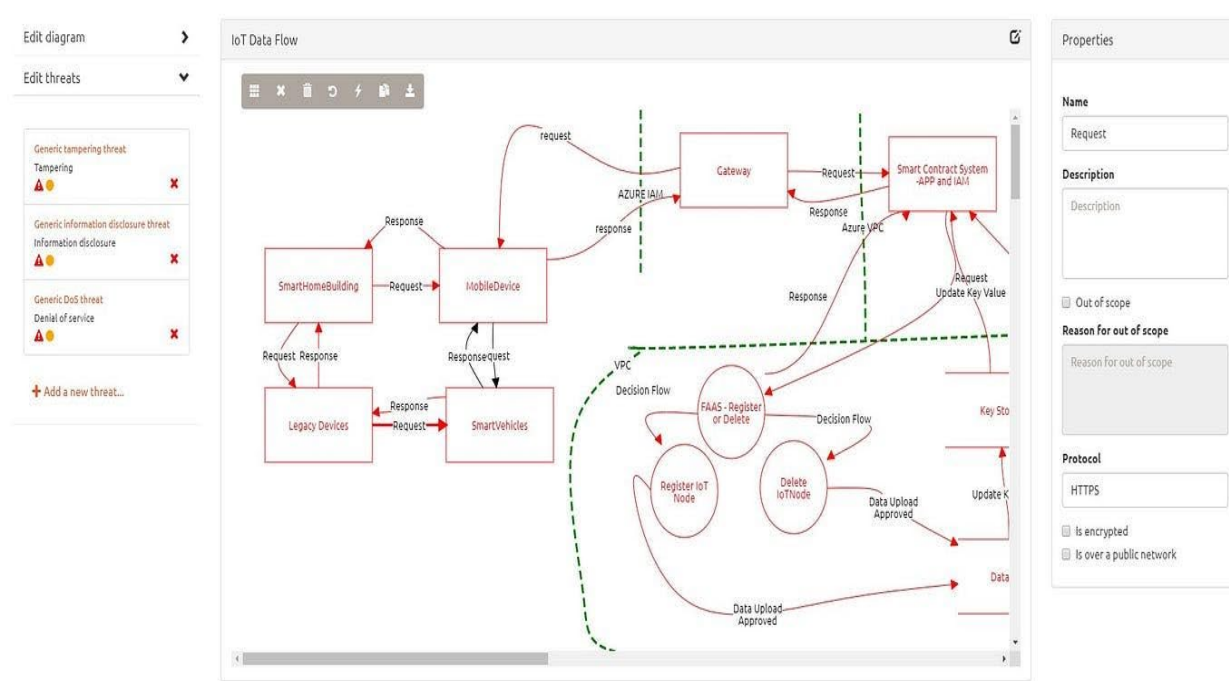
Herramientas: OWASP Threat Dragon y Microsoft Threat Modeling Tool.

1. Herramientas: OWASP Threat Dragon.



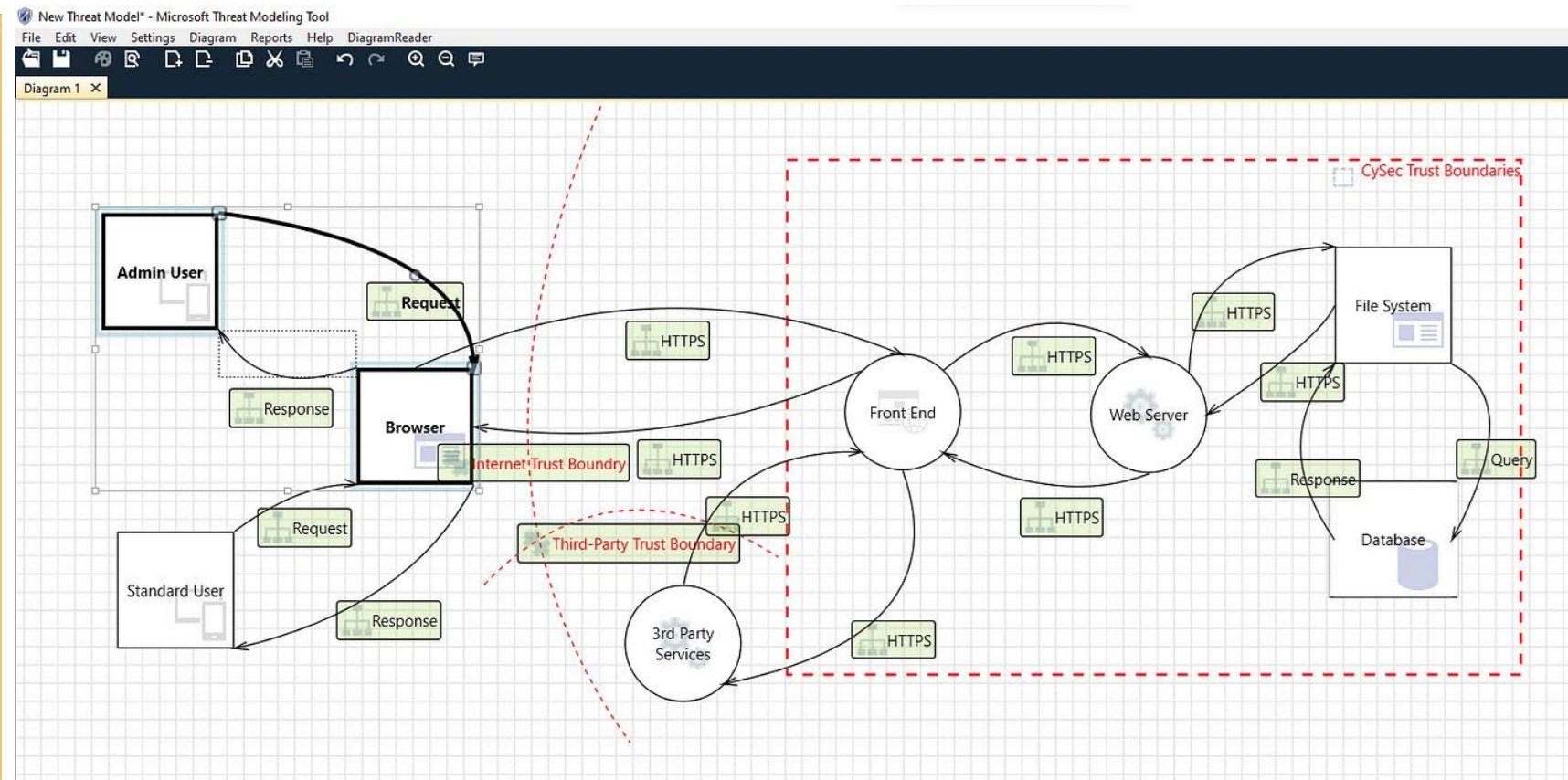
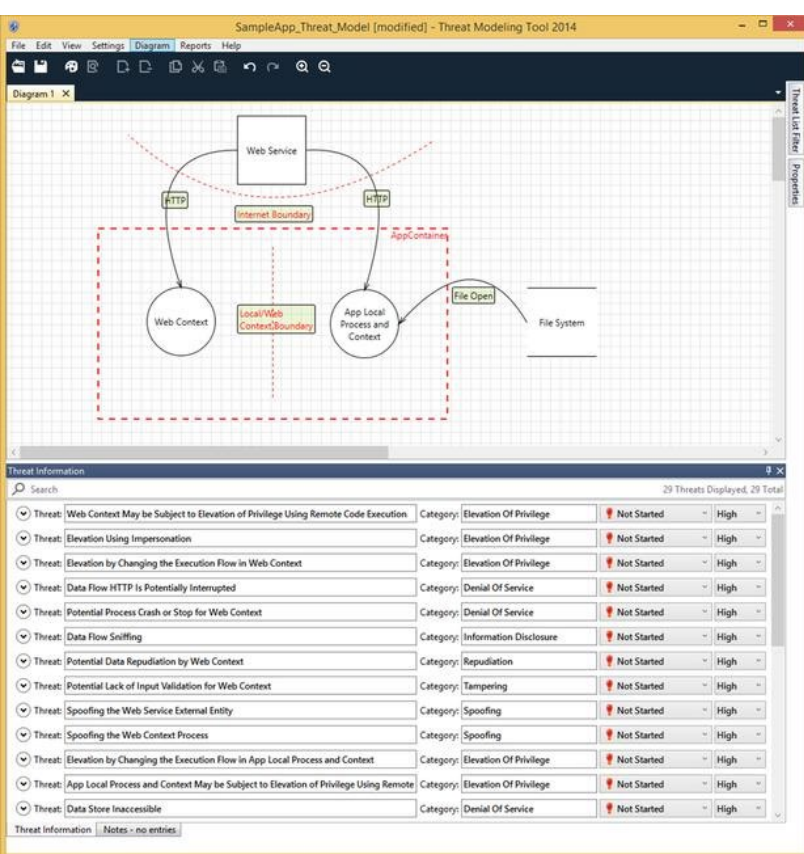
Herramientas: OWASP Threat Dragon y Microsoft Threat Modeling Tool.

1. Herramientas: OWASP Threat Dragon.

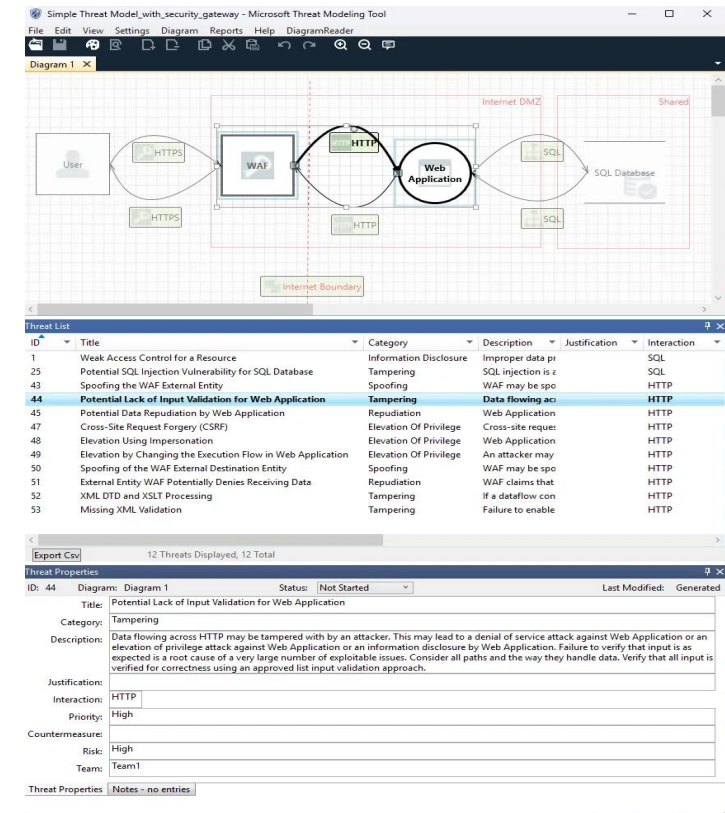


Herramientas: OWASP Threat Dragon y Microsoft Threat Modeling Tool.

2. Herramientas: Microsoft Threat Modeling Tool.



2. Herramientas: Microsoft Threat Modeling Tool.



Herramientas: OWASP Threat Dragon y Microsoft Threat Modeling Tool.

Herramientas: : OWASP Threat Dragon Vs. Microsoft Threat Modeling Tool.

Característica	OWASP Threat Dragon	Microsoft Threat Modeling Tool
Enfoque	Modelado flexible	Microsoft SDL
DFD	✓	✓
STRIDE	✓	✓
Otros enfoques	STRIDE, LINDDUN, CIA, DIE, PLOT4ai	Principalmente metodología Microsoft/STRIDE
Generación/gestión de amenazas	✓	✓
Mitigaciones	✓	✓
Reportes	✓	✓
Código abierto	Sí	No
Plataforma	Web y escritorio multiplataforma	Windows
Uso académico	Muy apropiado	Muy apropiado, especialmente para enseñar SDL

La herramienta NO sustituye el análisis del especialista; estructura, automatiza y documenta el proceso de identificar amenazas y diseñar sus mitigaciones.

Herramientas: OWASP Threat Dragon y Microsoft Threat Modeling Tool.

Comparación de herramientas de modelado de amenazas

OWASP Threat Dragon vs. Microsoft Threat Modeling Tool

Misma metodología, diferentes enfoques



Maestría en Seguridad de Sistemas
Modelar hoy,
prevenir mañana

¿Qué ofrecen y en qué se diferencian?

Característica	OWASP Threat Dragon	Microsoft Threat Modeling Tool
Enfoque	Modelado flexible	Microsoft SDL
DFD	✓	✓
STRIDE	✓	✓
Otros enfoques	STRIDE, LINDDUN, CIA, DIE, PLOT4ai	Principalmente metodología Microsoft/STRIDE
Generación/gestión de amenazas	✓	✓
Mitigaciones	✓	✓
Reportes	✓	✓
Código abierto	Si	No
Plataforma	Web y escritorio multiplataforma	Windows
Uso académico	Muy apropiado	Muy apropiado, especialmente para enseñar SDL

¿Qué tienen en común?

Ambas herramientas permiten aplicar la misma metodología de modelado de amenazas:



DFD (arquitectura del sistema) → Identificación de amenazas (STRIDE) → Mitigaciones (controles) → Documentación y reportes

La herramienta no reemplaza la metodología; la potencia y facilita su aplicación.

¿Dónde está la principal diferencia?

**OWASP Threat Dragon**

- Flexible y abierta
- Varias metodologías
- Comunidad OWASP
- Multiplataforma
- Código abierto

**Microsoft Threat Modeling Tool**

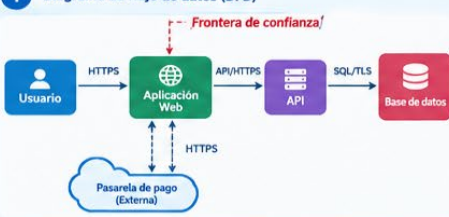
- Enfoque SDL
- Orientada a desarrollo seguro
- Más estructurada
- Ecosistema Microsoft
- Solo Windows

¿Qué podemos analizar y discutir ?

- **Elegir la herramienta adecuada**
Según el contexto del proyecto, el ecosistema tecnológico, la metodología y el equipo.
- **Comparar metodologías y enfoques**
Ambas usan STRIDE, pero una ofrece más opciones de análisis (LINDDUN, CIA, DIE, PLOT4ai).
- **Aplicar en un mismo caso**
Construir el DFD de un sistema, identificar amenazas, registrar mitigaciones y analizar los resultados en ambas herramientas.
- **Interpretar los resultados**
La herramienta identifica amenazas, pero es el profesional quien evalúa el impacto, el contexto y la decisión final.
- **Conectar con el ciclo completo**
Desde el modelado hasta la priorización y tratamiento del riesgo, para diseñar un sistema seguro.

Ejemplo práctico: Plataforma de comercio electrónico

1 Diagrama de flujo de datos (DFD)



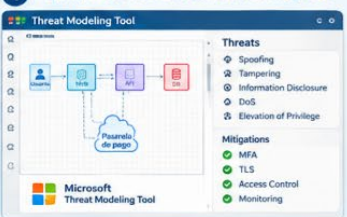
2 Amenazas identificadas (STRIDE)

Componente	Tipo (STRIDE)	Amenaza
Aplicación Web	Spoofing	Robo de credenciales
API	Tampering	Modificación de datos
API	Information Disclosure	Exposición de información
Base de datos	Elevation of Privilege	Acceso no autorizado
Todo el sistema	Denial of Service	Saturación de servicios
Pasarela de pago	Repudiation	Negación de transacciones

3 Ejemplo en OWASP Threat Dragon



4 Ejemplo en Microsoft Threat Modeling Tool



Decisión final: ¿Cuál elegir?

**✓ Elige OWASP Threat Dragon si:**

- Necesitas flexibilidad y más metodologías.
- Prefieres código abierto.
- Trabajas en diferentes plataformas.

**✓ Elige Microsoft Threat Modeling Tool si:**

- Usas el ecosistema Microsoft.
- Quieres integración con SDL.
- Prefieres una herramienta más estructurada.

Mensaje clave

"Las herramientas facilitan el modelado; el valor real está en la capacidad del profesional para interpretar las amenazas y convertirlas en decisiones de seguridad."

Actividad sugerida para la clase

1. Construir un DFD del sistema propuesto.
2. Identificar amenazas con STRIDE.
3. Registrar mitigaciones en ambas herramientas.
4. Comparar resultados y discutir diferencias.
5. Concluir: ¿qué herramienta usarías y por qué?

MASI 2026 · Seguridad en Aplicaciones · 093-013

Semana 2

Secuencia de actividades

- 1 **Foro de apertura:** experiencia previa del participante con seguridad en el desarrollo y expectativas del curso.
- 2 Configuración del entorno: repositorio Git de práctica, contenedores y herramientas base (Semgrep, Dependency-Check, ZAP) en máquina virtual o entorno cloud gratuito.
- 3 Análisis de caso: brecha reciente originada por un defecto de software — lección de diseño o de codificación aplicable al contexto guatemalteco.

Tareas y evaluaciones

8 tareas individuales en total (10 pts c/u, semanas 1 a 8) · 1 único trabajo final grupal (20 pts)

Tarea T2 (individual): modelo de amenazas completo (DFD, STRIDE, priorización y casos de abuso) con OWASP Threat Dragon.

10 pts

PARA LA PRÓXIMA SESIÓN

Lecturas sugeridas

1

OWASP Foundation. (2024). OWASP Threat Dragon. [\[Acceder\]](#)

2

Microsoft. (2024). Security Development Lifecycle — Threat Modeling. [\[Acceder\]](#)

3

OWASP Foundation. (2024). OWASP Cheat Sheet Series. [\[Acceder\]](#)

Gracias!
